

1 Appendix

1.1 A. Taxonomy of *RequirementClass* (RC) in DBE

1.1.1 Related Work A variety of classification frameworks/taxonomies exist in requirements engineering and privacy-oriented research. In general RE practice, requirements are commonly distinguished into functional and non-functional requirements, with quality characteristics often structured using models such as ISO/IEC 25002¹. is widely recognized in standards and quality models. ISO/IEC/IEEE 29148² provides detailed requirements engineering guidance. In privacy-oriented research, several conceptual frameworks are influential that provides insightful dimensions for requirements taxonomies. The NIST Privacy Framework³ explicitly framed system-level privacy objectives as system capabilities that help demonstrate privacy policy and requirements implementation. Hoepman Privacy Design Strategies [7] (e.g., minimise, separate, hide, inform, control) provides a stable decomposition of privacy intents/strategies. While these standards or frameworks are well-established, it is hard to directly introduce them into our methodology as a stable artefact: (1) None of them directly provide an integrated taxonomy that simultaneously captures functional capability requirements and privacy risk-control requirement classes. (2) Existing theories are overly broad and generic and do not reflect DBE-specific functional capabilities and privacy risks. (3) Presenting multiple overlapping taxonomies without consolidation may create ambiguity for readers regarding which classification scheme is used to derive architectural constraints.

Hence, for methodological clarity, a unified RC taxonomy is necessary to serve as a stable abstraction layer in the conceptual meta-model. Research in DBEs usually emphasizes cross-organization data exchange, governance, and interoperability as core characteristics. Our taxonomy construction starts from the general requirement classes and takes [6] as a reference for focusing on the DBE-related requirement class taxonomy.

1.1.2 RequirementClass Taxonomy The taxonomy is constructed according to four principles:

- **Problem-space orientation:** Each class within RC represents a category of system requirements, distinct from specific threats or architectural solutions.
- **Functionality and risk duality:** Functional *RequirementClasses* capture the types of utility the system must provide, while Privacy *RequirementClasses* capture the risk control mandates the system must enforce.
- **Separation from contextual factors:** *RequirementClasses* are normative and stakeholder-oriented, distinguishing them from adversary-oriented *ThreatCategories* and solution-oriented *ArchitecturalConstraints*.
- **DBE relevance:** The taxonomy addresses recurring requirement patterns specific to cross-organizational Digital Business Ecosystems (DBE).

The resulting taxonomy consists of two primary branches: Functional *Requirement Class* and Privacy *Requirement Class*.

¹<https://www.iso.org/standard/78175.html>

²<https://www.iso.org/obp/ui/en/#iso:std:iso-iec:29148:ed-2:v1:en>

³<https://www.nist.gov/privacy-framework>

ID	Requirement Description
A Functional RequirementClass	
A1 Identity & Role Management	
A1-1	Representation of multiple identities and roles.
A1-2	Binding of identities to logical subjects.
A1-3	Assurance of cross-domain identity continuity.
A2 Authentication & Authorization	
A2-1	Federation of authentication mechanisms.
A2-2	Enforcement of cross-domain authorization decisions.
A2-3	Delegation and revocation of access rights.
A3 Data Provisioning & Interoperability	
A3-1	Governance of local data via standardized interfaces.
A3-2	Retrieval of data across domain boundaries.
A3-3	Maintenance of semantic and syntactic interoperability.
A4 Data Processing & Analytics	
A4-1	Composition of data from heterogeneous sources.
A4-2	Composition of data across distinct contexts.
A4-3	Aggregation of metrics over subject sets.
A5 Accountability & Governance	
A5-1	Traceability of access events and decision logs.
A5-2	Provenance tracking for computation data lineage.
A5-3	Enforcement of compliance policies.
B Privacy RequirementClass	
B1 Transparency & Predictability	
B1-1	Clarification of data usage semantics.
B1-2	Predictability of data processing outcomes.
B2 Intervenable & Control	
B2-1	Mechanism for subject participation and consent revocation.
B2-2	Governance over access policies.
B2-3	Control over data lifecycle and retention.
B3 Unlinkability	
B3-1	Limitation of cross-context association.
B3-2	Prevention of cross-identifier correlation.
B3-3	Restriction of association persistence.
B4 Confidentiality	
B4-1	Protection against unauthorized data disclosure.
B4-2	Mitigation of inference & re-identification vectors.
B4-3	Protection of sensitive relationships.

1.2 B. Taxonomy of *ThreatClass* (TC) in DBEs

To construct the TC taxonomy, we directly adopt the privacy threat trees defined in the LINDDUN method⁴. LINDDUN provides a well-established and widely accepted privacy threat taxonomy structured around seven primary categories as top layers: TC-1. Linkability, TC-2. Identifiability, TC-3. Non-repudiation, TC-4. Detectability, TC-5. Information Disclosure, TC-6. Unawareness, and TC-7. Non-compliance. Each category is further refined into more concrete threat characteristics. These categories are adversary-centric and describe distinct classes of privacy harms that may arise from system design decisions.

⁴<https://linddun.org/threat-trees/>

1.3 C. Taxonomy of *ContextConditionClass* (CCC) in DBEs

Digital business ecosystems are consistently characterized by (i) multi-actor participation and co-evolution around a platform, (ii) distributed ownership/control and governance, and (iii) interoperability and cross-party value creation [10, 13]. We structured a taxonomy of *ContextConditionClass* (CCC) items restricted to privacy-relevant contextual facts for DBEs based on several existing research [3, 11, 12, 14].

DBE general component. Following the digital business ecosystem research, we use the following term in CCC taxonomy : (1) We use *Organization* to denote an autonomous ecosystem actor that owns resources, governs its services, and maintains control over its data. (2) We use *Participant* as a generic term referring to any actor or technical component involved in the interaction. (3) A *Coordination Intermediary* denotes a service or subsystem used to route, orchestrate, or aggregate interactions across organizations, as commonly observed in ecosystem architectures. Such intermediaries support coordination but are not assumed to act as globally trusted authorities. (3) An *Infrastructure Component* refers to a technical component that stores, processes, or relays data within the system. (5) A *Trusted Authority* denotes an entity broadly trusted by participating organizations to perform privacy-critical operations. Many DBE scenarios explicitly lack such an authority.

CCC1. Trust, Control & Adversarial Assumptions: This category captures how trust and control are distributed across DBE participants and what adversarial assumptions must be considered. These assumptions directly influence whether architectural derivations may rely on trusted intermediaries, centralized coordination, or require distributed trust mechanisms. Trust distribution is a primary decisive factor of privacy-aware architecture feasibility in multi-stakeholder systems.

- CCC1-1. Absence of centralized trusted authority.
- CCC1-2. Independent organizations with mutually limited trust.
- CCC1-3. Limited trust scope for coordination intermediaries.
- CCC1-4. Honest-but-curious participant assumption.
- CCC1-5. Possibility of bounded collusion among participants.
- CCC1-6. Infrastructure components are not fully trusted with plaintext-sensitive data⁵.

CCC2. Identity & Identifier: This category captures structural properties of identity representation across ecosystem domains. These conditions are architectural facts that influence how identity linkage, authentication, and aggregation can be performed.

- CCC2-1. Identifiers are fragmented (organization-scoped) and no shared global identifier infrastructure can be assumed.
- CCC2-2. Identity-linkage information is classified as sensitive.

⁵Plaintext refers to data represented in directly intelligible form to the component processing it, regardless of whether storage or API-level access control is present. This is distinguished from protected representations such as encrypted, tokenized, masked, or secret-shared data, where the component cannot directly inspect the underlying sensitive values.

CCC3. Data Custody, Access & Computation : This category captures structural context regarding data custody and whether computation and queries must operate across administrative trust boundaries. These structural properties strongly influence feasible architectural derivations and privacy-preserving coordination mechanisms.

- CCC3-1. Each organization/participant remains their own data custody.
- CCC3-2. Scenario functionality requires cross-organization data processing.
- CCC3-3. Cross-domain data processing occurs across administrative trust boundaries.

1.4 D. Taxonomy of *Technology Feature* (TF) for PETs

Contemporary literature and practitioner guidelines on Privacy Enhancing Technologies (PETs) increasingly advocate for characterizing solutions based on functional capabilities, trust assumptions, leakage profiles, and trade-offs, rather than merely cataloging specific protocols (e.g., MPC, Homomorphic Encryption, or TEEs) [1, 2, 4]⁶. This shift emphasizes the selection of technologies based on their architectural properties and alignment with deployment constraints.

Consequently, we synthesize a *Technical Feature* (TF) taxonomy inspired by PET evaluation frameworks and surveys mentioned above. This taxonomy is structured around capability guarantees and select relevant properties about what a technique provides rather than utilizing specific PET families (e.g., "MPC/HE") as taxonomic nodes. In our framework, specific PET protocols are categorized as *TechnicalInstantiation* (TI). Thus, TF serves as the abstract technology feature dimension that links the refined requirements of *SolutionDesignCandidates* (SDCs) with the provisions of specific TIs.

TF1. Computation Mechanism

- TF1-1. Joint computation without raw data sharing.
- TF1-2. Computation over protected data representations.
- TF1-3. Computation within isolated execution environments.

TF2. Disclosure and Leakage Control

- TF2-1. Protection of intermediate computation states.
- TF2-2. Restriction of outputs to necessary functional results.
- TF2-3. Limitation of statistical inference from released results.
- TF2-4. Protection of query targets, record existence, or access patterns.

TF3. Adversary Model Compatibility

- TF3-1. Party behaviour assumption (e.g., semi-honest, malicious).
- TF3-2. Collusion assumption (e.g., non-colluding, bounded collusion, threshold corruption).
- TF3-3. Verifiability support (e.g., none, partial, explicit).

TF4. Supported Cross-Party Data Relationship

- TF4-1. Same-schema data aggregation across parties.

⁶<https://www.enisa.europa.eu/news/enisa-news/enisas-pets-control-matrix-a-tool-to-evaluate-online-and-mobile-privacy-tools>

- **TF4-2.** Cross-party attribute combination for overlapping entities.
- **TF4-3.** Privacy-preserving set comparison or matching.
- **TF4-4.** Privacy-preserving entity linkage across organizations.

TF5. Integration Modality

- **TF5-1.** Batch-style execution.
- **TF5-2.** Interactive multi-round execution.
- **TF5-3.** API-mediated service integration.
- **TF5-4.** Embedded execution within an application component.

1.5 E. Reusable FeasibilityFactor List for Candidate Comparison

A *FeasibilityFactor* (FF) is a reusable comparison dimension used in *CandidateFeasibilityAssessment* (CFA). Its purpose is to compare admissible *SolutionDesignCandidates* after the hard-gate *SatisfactionChecks* have been passed. In this sense, FF supports candidate comparison rather than constraint derivation.

In the current framework, *FeasibilityFactor* (FF) is modeled as a reusable but extensible artefact for candidate comparison, rather than as a fixed or exhaustive taxonomy. The following items illustrate typical FFs that may be instantiated depending on the case context. They are synthesized from architecture trade-off evaluation and privacy engineering literature, which emphasize comparison across quality attributes, deployment suitability, and organizational/operational constraints in privacy-preserving system design [5, 8, 9, 15] ⁷.

- **FF-DC: Deployment compatibility.** Compatibility with the existing ecosystem baseline, infrastructure assumptions, and administrative boundaries.
- **FF-WC: Workflow coordination complexity.** The degree of cross-party coordination and orchestration required during normal operation.
- **FF-CO: Cryptographic interaction overhead.** Communication, synchronization, and runtime cost introduced by privacy-preserving computation.
- **FF-GB: Governance and operational burden.** Cross-organizational effort required for operation, trust management, and responsibility allocation.
- **FF-IT: Implementation tractability.** Engineering effort, technical maturity, and practical implementability under project constraints.
- **FF-TA: Trust-assumption alignment.** The extent to which the candidate's trust model fits the ecosystem context.
- **FF-SM: Scalability and maintainability.** The extent to which the candidate remains workable and maintainable as the ecosystem evolves.
- **FF-II: Integration and interoperability impact.** The extent to which the candidate preserves or complicates interoperability with surrounding services and APIs.

Not all FFs need to be instantiated in every case. A case selects only those factors that are decision-relevant after admissibility screening.

⁷<https://www.enisa.europa.eu/publications/privacy-and-data-protection-by-design>

1.6 F. Complete Architectural Constraints and Satisfaction Checks for Validation Reference

This appendix presents the complete set of *ArchitecturalConstraints* (ACs) and *SatisfactionChecks* (SCs) used as the reference basis for the *ValidationEvidence* in Sec.???. Each *SatisfactionCheck* is defined as the operationalization of a corresponding *ArchitecturalConstraint*.

1.6.1 Architectural Constraints We preselect the full list of ACs in MUSIC360 scenario:

AC-1: No plaintext linkage disclosure: No participant or system component outside the authorized secure-processing boundary shall be able to obtain or persist plaintext cross-role linkage information.

AC-2: Secure processing of raw role-specific identifiers: Raw role-specific identifiers may be processed only within authorized secure-processing paths, and such processing shall not disclose the identifiers or the resulting cross-role linkage to unauthorized parties.

AC-3: No persistent global identifier: The architecture shall prevent the exposure of any persistent linkage-bearing identifier that can serve as a reusable cross-domain reference.

AC-4: Functional correctness of identity linkage: The architecture shall enable correct cross-role identity linkage sufficient to support the required linkage-dependent functionality.

AC-5: No leakage through intermediate or unnecessary outputs: The architecture shall ensure that only functionally necessary outputs are released, while intermediate linkage information and unnecessary disclosure remain protected.

1.6.2 Satisfaction Checks We preselect the full list of SCs in MUSIC360 scenario:

SC-1 (operationalizing AC-1): No system component outside the authorized secure-processing boundary stores or persists plaintext cross-role linkage information.

SC-2 (operationalizing AC-2): Raw role-specific identifiers are used only within authorized verification or secure-processing paths and are not disclosed to unauthorized parties during linkage-related processing.

SC-3 (operationalizing AC-2): Identity-linkage computation occurs only within an authorized secure-processing mechanism that prevents external disclosure of sensitive identifiers and of the resulting linkage.

SC-4 (operationalizing AC-3): No persistent linkage-bearing identifier is disseminated across organizational or system boundaries.

SC-5 (operationalizing AC-4): The architecture correctly supports the intended linkage-dependent functions, including cross-role identity continuity and aggregate-result generation.

SC-6 (operationalizing AC-5): Intermediate linkage information and sensitive computation states are not disclosed outside the secure-processing boundary, and only necessary outputs are released.

References

- [1] J.M. Auñón, D. Hurtado-Ramírez, L. Porras-Díaz, B. Irigoyen-Peña, S. Rahmian, Y. Al-Khazraji, J. Soler-Garrido, and A. Kotsev. 2024. Evaluation and utilisation of privacy enhancing technologies—A data spaces perspective. *Data in Brief* 55 (2024), 110560. <https://doi.org/10.1016/j.dib.2024.110560>

- [2] Michael Colesky, Jaap-Henk Hoepman, and Christiaan Hillen. 2016. A critical analysis of privacy design strategies. In *2016 IEEE security and privacy workshops (SPW)*. IEEE, 33–40.
- [3] Abide Coskun-Setirek, Maria Carmela Annosi, William Hurst, Wilfred Dolfmsma, and Bedir Tekinerdogan. 2024. Architecture and governance of digital business ecosystems: a systematic literature review. *Information Systems Management* 41, 1 (2024), 58–90.
- [4] Olha Drozd. 2015. Privacy pattern catalogue: A tool for integrating privacy principles of ISO/IEC 29100 into the software development process. In *IFIP International Summer School on Privacy and Identity Management*. Springer, 129–140.
- [5] Gonzalo Munilla Garrido, Johannes Sedlmeir, Ömer Uludağ, Ilias Soto Alaoui, Andre Luckow, and Florian Matthes. 2022. Revealing the landscape of privacy-enhancing technologies in the context of data markets for the IoT: A systematic literature review. *Journal of Network and Computer Applications* 207 (2022), 103465.
- [6] Joshua Gelhaar, Tobias Groß, and Boris Otto. 2021. A taxonomy for data ecosystems. (2021).
- [7] Jaap-Henk Hoepman. 2014. Privacy design strategies. In *IFIP International Information Security Conference*. Springer, 446–459.
- [8] Rick Kazman, Mark Klein, and Paul Clements. 2000. ATAM: Method for architecture evaluation. (2000).
- [9] Alexandra Klymenko, Stephen Meisenbacher, Luca Favaro, and Florian Matthes. 2024. On the Integration of Privacy-Enhancing Technologies in the Process of Software Engineering.. In *ICEIS (2)*. 41–52.
- [10] Dominik Lis and Boris Otto. 2021. Towards a taxonomy of ecosystem data governance. (2021).
- [11] Sandip Mukhopadhyay and Harry Bouwman. 2019. Orchestration and governance in digital platform ecosystems: a literature review and trends. *Digital Policy, Regulation and Governance* 21, 4 (2019), 329–351.
- [12] Irina Rychkova, Jelena Zdravkovic, and Janis Stirna. 2023. Implications of trust in digital business ecosystem design: A systematic analysis of roles.. In *PoEM Companion*.
- [13] Prince Kwame Senyo, Kecheng Liu, and John Effah. 2019. Digital business ecosystem: Literature review and a framework for future research. *International Journal of information management* 47 (2019), 52–64.
- [14] Tijs van den Broek and Anne Fleur van Veenstra. 2018. Governance of big data collaborations: How to balance regulatory compliance and disruptive innovation. *Technological Forecasting and Social Change* 129 (2018), 330–338.
- [15] Michiel Willocx, Vincent Reniers, Dimitri Van Landuyt, Bert Lagaisse, Wouter Joosen, and Vincent Naessens. [n.d.]. Privacy-preserving Data Sharing Collaborations: Architectural Solutions and Trade-off Analysis.. In *The Seventeenth International Conference on Advances in Databases, Knowledge, and Data Applications*.